# Práctica. Cierra la auditoría: reverifica y escribe el informe

Nombre y apellidos: _____

**Jueves 26 de noviembre de 2026 · HE · 4 horas · trabajo individual**

Una auditoría no termina cuando encuentras los fallos: termina cuando entregas un informe que alguien puede leer y actuar, y cuando compruebas que las correcciones funcionan. Eso es lo de hoy. El jueves pasado encontraste y confirmaste los fallos de tu web. El lunes, en Puesta en Producción Segura, los arreglaste. Hoy vuelves a pasar **las mismas pruebas** sobre la web ya bastionada, apuntas qué ha cambiado, y escribes el informe formal de la auditoría completa: de principio a fin, con el antes y el después.

Esta es, probablemente, la habilidad que más te van a pagar: no romper, sino explicar por escrito, con evidencia y sin exagerar, qué estaba mal, cómo de grave era y si ya está resuelto.

## 1. Qué vas a aprender hoy

1. Reverificar hallazgos: repetir la prueba exacta sobre el sistema corregido.
2. Documentar el antes y el después de cada hallazgo con evidencia.
3. Escribir un informe de auditoría con sus apartados estándar.
4. Redactar un resumen ejecutivo para quien no es técnico.
5. Dar una recomendación final honesta sobre si el sistema está listo.

## 2. Lo que necesitas

Tu plantilla de la auditoría del 19 (con los hallazgos, los comandos y las horas) y tu web del 24 ya bastionada, arrancada en tu Ubuntu. Desde la Kali, por la red solo-anfitrión, como el jueves pasado. Descarga de la web del curso (HE, Prácticas) la `plantilla-informe-auditoria.md`.

Comprueba que llegas a tu web:

```
WEB=http://192.168.56.1:8080
curl -sI $WEB/salud
```

## 3. Reverifica cada hallazgo (70 minutos)

La regla de oro de la reverificación: **se repite la prueba exacta que confirmó el fallo**, ni más floja ni más fuerte. Si antes lo confirmaste con un comando, hoy corres ese mismo comando y comparas. Ve rellenando la tabla de reverificación de la plantilla.

### 3.1. Inyección SQL

```
curl -s -b cookie.txt -o /dev/null -w "%{http_code}\n" "$WEB/buscar?q=%27"
curl -s -b cookie.txt "$WEB/buscar?
q=zz%27%20UNION%20SELECT%20id,nombre,hash,rol%20FROM%20usuarios--%20" | grep -i
scrypt
```

(Necesitas estar logueado, como el jueves; guarda la cookie con el mismo `curl ... -c cookie.txt` del login.) Antes, la comilla daba 500 y la UNION sacaba hashes. Si ahora la comilla da 200 y la UNION no devuelve ningún `scrypt`, el hallazgo está **corregido**. Apúntalo.

### 3.2. IDOR

```
curl -s -b cookie.txt -o /dev/null -w "%{http_code}\n" "$WEB/reservas/1"
```

Antes daba 200 (veías la reserva de otro). Si ahora da 404, corregido.

### 3.3. Enumeración de usuarios

```
curl -s -d "nombre=lucia&clave=x"    $WEB/login | grep -oiE "no
existe|incorrect[oa]s?"
curl -s -d "nombre=noexiste&clave=x" $WEB/login | grep -oiE "no
existe|incorrect[oa]s?"
```

Antes, mensajes distintos. Si ahora los dos dan el mismo, corregido.

### 3.4. Fuerza bruta

Repite el `ffuf` del jueves con `claves.txt`. Antes probaba toda la lista; ahora, a los pocos intentos, la web debería responder 429 (demasiados intentos). Comprueba qué código sale cuando te pasas.

### 3.5. XSS

Crea una reserva con `<script>alert(1)</script>` en el motivo y ábrela en el navegador. Antes saltaba; ahora tiene que verse el texto tal cual, sin ejecutarse.

### 3.6. Cabeceras

```
curl -sI $WEB/ | grep -iE "x-frame-options|content-type-options|content-
security-policy"
```

Antes no estaban; ahora tienen que aparecer.

## 4. Escribe el informe (90 minutos)

Abre `plantilla-informe-auditoria.md` y complétala entera. Los apartados son los de un informe real:

- **Alcance y metodología**: qué auditaste, cuándo, cómo y con qué (ya casi está en la plantilla; ajústalo a lo que hiciste tú).
- **Resumen de hallazgos**: la tabla con cada hallazgo, su tipo OWASP, su nota CVSS y su estado antes (19) y después (26).
- **Detalle de cada hallazgo**: descripción, la prueba que lo confirmó (comando y evidencia), el impacto, la recomendación y el resultado de la reverificación. Escríbelo para que lo entienda quien tiene que arreglarlo.
- **Reverificación**: la tabla del apartado 3, con el resultado de hoy.
- **Conclusión**: ¿está la web lista para producción? ¿Qué quedaría? Sé honesto: si algo sigue flojo (por ejemplo, el límite de intentos es en memoria y se reinicia), dilo.

Al final, escribe el **resumen ejecutivo** (va el primero, se escribe el último): tres o cuatro líneas para quien decide, sin tecnicismos.

Cuida el tono: un informe no exagera ("¡catastrófico!") ni minimiza. Dice qué pasa, con qué evidencia y qué gravedad, y punto. La persona que lo lee tiene que poder fiarse de cada frase.

## 5. Preguntas

1. ¿Por qué en la reverificación se repite la prueba exacta y no una distinta?
2. De tus hallazgos, ¿cuántos están corregidos del todo y cuántos solo mitigados? ¿Qué diferencia hay?
3. ¿Qué le dirías en el resumen ejecutivo a alguien que solo va a leer esas cuatro líneas?
4. Si tuvieras que dejar un hallazgo sin arreglar por falta de tiempo, ¿cuál dejarías para el final y por qué?
5. ¿Dirías que la web está lista para producción? Justifícalo con tus datos.

## 6. Si algo no funciona

No llegas a la web desde la Kali: web arrancada en el Ubuntu (`sudo systemctl status miweb nginx`) y red solo-anfitrión como el 19. Si no, avísame.

Un hallazgo que esperabas corregido sigue apareciendo: no es un fallo tuyo de hoy, es que el bastionado del 24 no cerró ese punto. Apúntalo tal cual en el informe (estado: sigue presente) y, si te da tiempo, mira en tu código por qué. Un informe que dice la verdad vale más que uno que dice lo que querrías.

La UNION devuelve 200 pero sin datos: perfecto, eso es que está corregida (la consulta ya no inyecta). Lo que delata el fallo es que aparezcan los `scrypt`, no el código de respuesta.

## 7. Qué tienes que entregar (20 minutos)

Carpeta `NN-HE-informe` en ZIP con:

1. `plantilla-informe-auditoria.md` completa: el informe entero, con la tabla antes/después y el resumen ejecutivo.
2. Las evidencias de la reverificación (las salidas de los comandos del apartado 3).
3. Las respuestas a las preguntas del apartado 5.

Como siempre, no copies contraseñas ni volcados completos: con la evidencia de que el fallo estaba (o ya no) basta.

## 8. Antes de entregar, comprueba que

1. Cada hallazgo tiene estado antes (19) y después (26) con su evidencia.
2. El resumen ejecutivo se entiende sin ser técnico y no exagera.
3. La conclusión responde claramente si la web está lista o qué falta.
4. Todo lo que afirmas está respaldado por una prueba tuya.

## 9. Seguridad y cierre

Con esto cierras el ciclo completo que hemos hecho con una sola web: la construiste, la pusiste segura, la atacaste, la defendiste con tu SOC, la bastionaste y hoy certificas por escrito en qué estado queda. Ese recorrido —y sobre todo el informe honesto del final— es exactamente lo que hace un profesional de la seguridad. Guárdalo: es el mejor ejemplo de trabajo que podrás enseñar.

## Referencias

- OWASP Web Security Testing Guide, informe: https://owasp.org/www-project-web-security-testing-guide/stable/6-Reporting/README
- Guía de pruebas y reverificación (PTES): http://www.pentest-standard.org/index.php/Reporting
- CVSS 3.1, para las notas del informe: https://www.first.org/cvss/v3.1/specification-document